

REGULATORY & STATUTORY BLUEPRINT | WP-2026-03

Governing AI in Regulated Jurisdictions: Singapore PDPA & MAS TRM Compliance Standard for AI Deployments

Author: KaoinAI Regulatory Compliance & AI Systems Practice
Jurisdictional Scope: Singapore PDPC, Monetary Authority of Singapore (MAS), ASEAN Digital Data Governance Framework

Executive Summary: On March 2026, the Personal Data Protection Commission (PDPC) and the Monetary Authority of Singapore (MAS) issued stringent operational guidance regarding corporate accountability in Generative AI systems. Companies utilizing personal data to prompt, train, or ground autonomous models face severe financial penalties (up to 10% of annual turnover or \$1M SGD) for unauthorized PII extraction or opaque decisioning. This standard provides an operational architecture for maintaining continuous compliance.

1. Statutory Mandates Mapping: PDPC Advisory Guidelines on GenAI

The Singapore Advisory Guidelines mandate three non-negotiable principles for corporate AI systems:

PDPA Provision	Statutory Requirement	AI Implementation Challenge	KaoinAI Architectural Enforcement
Consent & Purpose (Section 20)	Personal data used only for stated business purposes	Shared data across multiple tenant boundaries	Zero-storage metadata extraction only
Protection Obligation (Section 24)	Prevent unauthorized access or accidental disclosure	Knowledge leakage exposes user NRICs and card details	Dynamic SHA-256 masking layer pre-prompt
Accountability Obligation (Part 4)	Demonstrable audit trail of data lineage	Neural networks operate as opaque black boxes	Deterministic lineage graph mapping SQL roots
MAS TRM 5.1 System Security	Continuous security testing and access control	Unauthorized dev roles querying staging databases	Autonomous RBAC column-level proxy scanning

2. Technical Enforcement: Pre-Prompt Dynamic Redaction

To satisfy the Protection Obligation without degrading the analytical utility of business queries, KaoinAI introduces an inline redaction proxy. When a user asks: 'Find high-risk credit transactions in Tampines', the system:

- Intercepts the natural language intent and tokenizes identified named entities (NER).
- Sanitizes table columns containing Singapore NRICs (S1234567A), phone numbers (+65-9...), and credit card PANs, substituting deterministic pseudonymized tokens.
- Synthesizes SQL against masked column schemas, ensuring that query telemetry logged into telemetry stores contains zero raw PII.
- Decrypts and resolves tokens only at the final authorized presentation tier within the client's internal session boundary.

3. Audit & Regulatory Readiness Checklist

- Immutable Query Log:** Retain 12-month query lineage logs containing timestamp, user role, and generated SQL.
- Automated DPA Generation:** Out-of-the-box Data Processing Agreements aligned with Singapore Personal Data Protection Commission templates.

- **Annual TRM Security Certification:** Architecture readiness verification for Monetary Authority of Singapore technology audits.